

LEY MARCO DE CIBERSEGURIDAD N°21.663

Matriz de Riesgos de Ciberseguridad

Normativa	Ley Marco de Ciberseguridad N°21.663
Organización	Laboratorio Clínico ACLIN Ltda.
Responsable de Ciberseguridad	Paulina Tapia Hernández (CISO)
Versión del documento	1.0
Período de cumplimiento	Octubre 2025 – Octubre 2026
Fecha de emisión	15 / 03 / 2026

Clasificación: Confidencial — Jaime Gómez Ayala — Auditor Externo de Ciberseguridad

1. PROPÓSITO

Identificar, analizar y evaluar los riesgos de ciberseguridad asociados a los activos críticos del Laboratorio Clínico ACLIN Ltda., permitiendo priorizar acciones de mitigación y fortalecer los controles de seguridad.

2. ALCANCE

La matriz considera riesgos asociados a sistemas clínicos, bases de datos de pacientes, infraestructura tecnológica, servicios cloud, redes y plataformas administrativas del laboratorio.

3. MARCO NORMATIVO

- Ley Marco de Ciberseguridad N°21.663
- ISO/IEC 27001 – Gestión de Seguridad de la Información
- ISO/IEC 27005 – Gestión de Riesgos de Seguridad
- NIST Risk Management Framework

4. METODOLOGÍA

Los riesgos se evalúan considerando Probabilidad (1–5) × Impacto (1–5). Resultado: Bajo 1–4 / Medio 5–9 / Alto 10–16 / Crítico 17–25.

5. MATRIZ DE RIESGOS

ID	Activo	Amenaza	Vulnerabilidad	Impacto	Probabilidad	Nivel	Controles	Tratamiento	Responsable
R-01	Servidor LIS	Ransomware	Sin EDR	5	3	Alto (15)	AV, Firewall	EDR + segmentación red	Área TI
R-02	BD Pacientes	Filtración datos	Credenciales débiles	5	3	Alto (15)	Control accesos	MFA + cifrado BD	CISO

R-03	Correo institucional	Phishing	Sin capacitación	4	4	Alto (16)	Filtro antiLtda. m	Capacitación usuarios	Área TI
R-04	Sistema backups	Falla en backup	Backups no probados	5	2	Medio (10)	Backups auto.	Pruebas trimestrales	Área TI
R-05	Red interna	Acceso no autorizado	FW desactualizado	4	3	Medio (12)	Firewall	Actualizar reglas	TI Infraestructura
R-06	pacientes.aclin.cl	IDOR - Acceso exáms. terceros	Sin validación sesión	5	5	CRÍTICO (25)	Ninguno	Validación sesión + reCAPTCHA	Desarrollo / TI
R-07	MSSQL (BD clínica)	Acceso remoto no autorizado	Puerto 1122 expuesto	5	4	CRÍTICO (20)	Ninguno	Cerrar puerto + FW perimetral	TI Infraestructura
R-08	pacientes.aclin.cl	MITM / interceptación	HTTP sin HTTPS	5	4	CRÍTICO (20)	Ninguno	SSL/TLS + HSTS	TI Infraestructura
R-09	IIS 10.0 (web server)	XSS / Clickjacking	Headers HTTP faltantes	3	2	Medio (6)	Ninguno	Config. Referrer-Policy, CSP, X-Frame	TI Infraestructura

RIESGOS CRÍTICOS ACTIVOS — Requieren intervención urgente:• R-06: IDOR en pacientes.aclin.cl — ~21.000 exámenes expuestos. Probabilidad × Impacto = 5 × 5 = 25.• R-07: MSSQL puerto 1122 abierto a Internet. Impacto = 5 × Probabilidad = 4 = 20.• R-08: HTTP sin cifrado. Transmisión de datos médicos interceptable. Impacto 5 × Prob. 4 = 20.

6. TRATAMIENTO DE RIESGOS

Los riesgos identificados deberán gestionarse mediante controles técnicos, procedimientos organizacionales, monitoreo continuo y planes de mitigación definidos en el Plan de Tratamiento de Riesgos.

7. REVISIÓN

La matriz de riesgos deberá revisarse al menos una vez al año o cuando existan cambios significativos en la infraestructura tecnológica.

8. APROBACIÓN · VIÑA DEL MAR, CHILE

Representante Legal / CEO – ACLIN Ltda.
Marcelo Tapia Carrere

Auditor Externo · RUT 16.302.178-1
Jaime Gómez Ayala

Firma

Firma

Fecha de aprobación: ____ / ____ / 2026